

黑马点评 · 登录模块

从 Toy 实现到企业化改造

Spring Boot 2.7

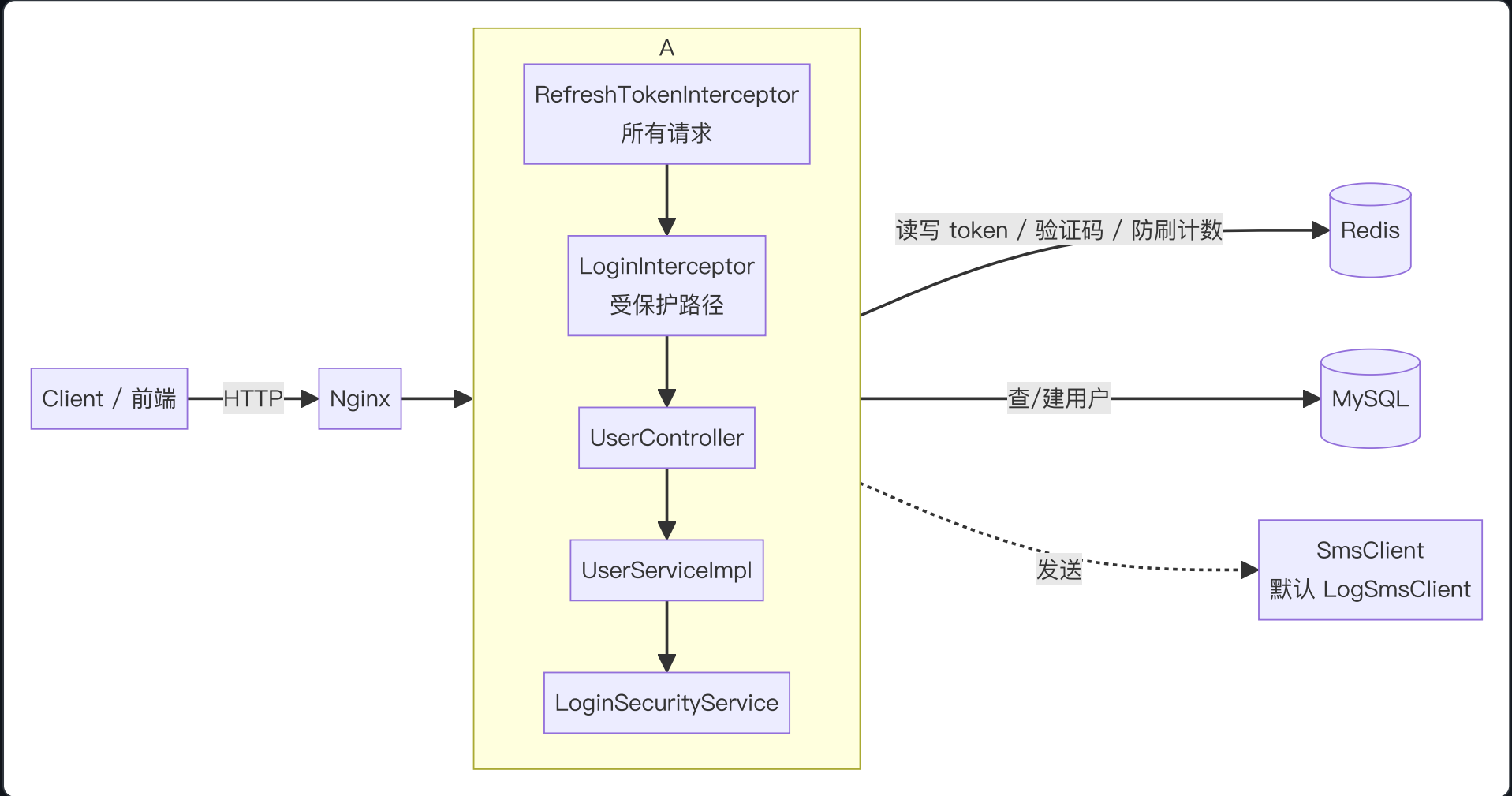
Redis

StringRedisTemplate

Jackson

双拦截器

SHA-256



原版本的 6 个 "Toy 味" 问题

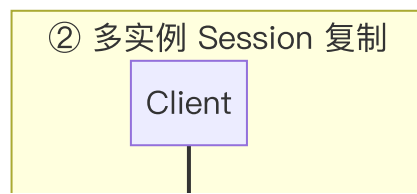
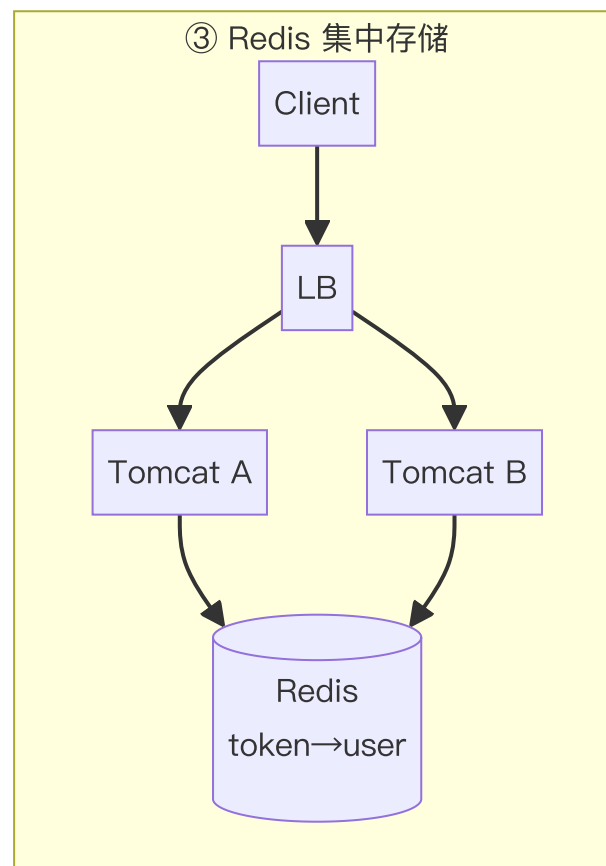
03 / 11

1. ① 同手机号可无限刷验证码（无 60s 间隔，无日上限）—— 一夜烧光短信费
2. ② 验证码明文存 Redis —— Redis 一旦泄露 = 验证码全裸
3. ③ 验证码错误次数不限 —— 6 位数字暴力枚举可破
4. ④ 短信发送写死成 log.debug —— 永远接不上真实服务商
5. ⑤ Token 续期每次请求都写 Redis —— 写放大，热 key 风险
6. ⑥ 用户信息用 Hash 存，字段全转 String —— 类型丢失，DTO 还得手动转

这 6 个点，企业里任何一个都会被 review 打回。

方案演进：Session → Redis Token

04 / 11



主流程时序图（改造后）



Syntax error in text
mermaid version 10.9.6

安全层 ①：防刷 + 哈希 + 锁定

06 / 11

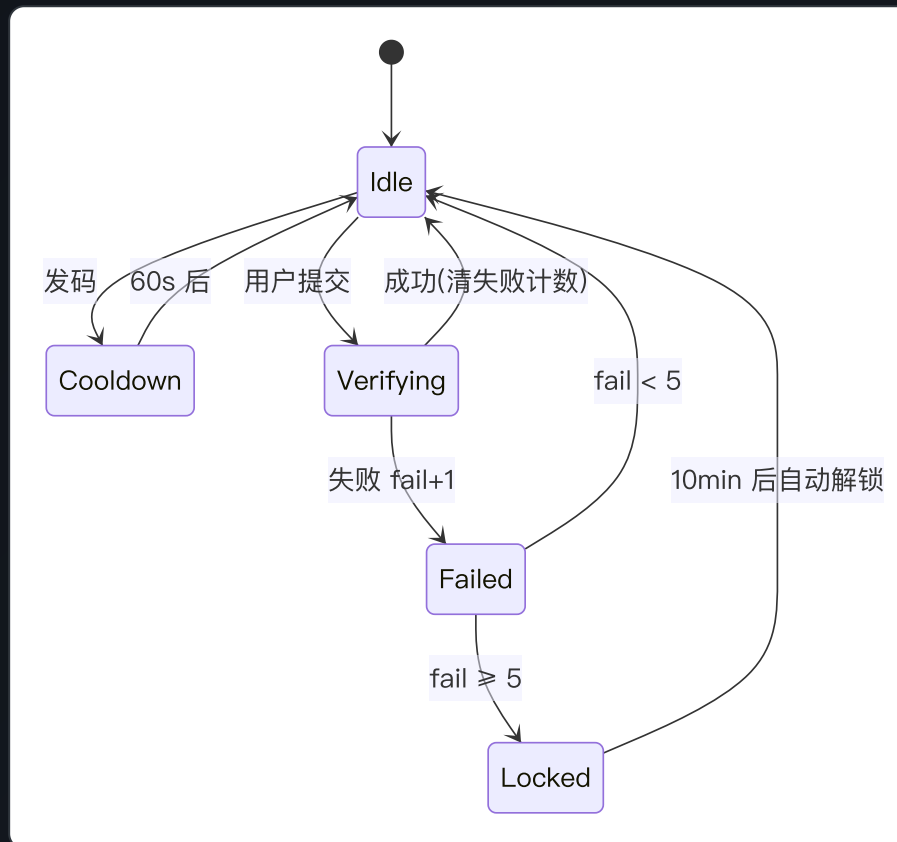
三道闸门

- 冷却：60s 内重复发同号 → 拒绝
- 日上限：单号每日 10 次 → 拒绝
- 锁定：连错 5 次 → 锁 10 分钟，期间发码/登录都拒

哈希存储

Redis 存 `SHA-256(phone + code + salt)`，盐通过 `hmdp.login.code-salt` 配置。

就算 Redis 被脱库，攻击者也拿不到原始 code。



安全层 ②: SmsClient 抽象

07 / 11

为什么要抽象

- 原版直接 `log.debug`, 永远上不了生产
- 不同环境需要不同实现: 日志 / 阿里云 / 腾讯云 / 自研网关
- 测试态可注入 Mock, 记录调用

实现替换方式

新增 `AliyunSmsClient` implements `SmsClient`, 加 `@Primary` 或 `@ConditionalOnProperty` 即可, `UserServiceImpl` 零改动。



Syntax error in text
mermaid version 10.9.6

会话改造 ①：JSON 替代 Hash

	Hash (原版)	JSON String (改造后)
读写命令	HSET / HGETALL, 多 field	SET / GET, 一次完成
类型保真	所有值转 String, Long → "123"	Jackson 反序列化还原
反序列化代码量	BeanUtil.fillBeanWithMap, 依赖反射猜类型	objectMapper.readValue, 类型明确
部分字段更新	支持 HSET 单字段	需要整体 GET → 改 → SET
调试可读性	HGETALL 多字段	GET 一行 JSON 一目了然

取舍：登录态字段总量小 (id/nickName/icon)，整体读写是常态，没有"只改一个字段"的场景。JSON 更合适。

会话改造 ②：滑窗续期

09 / 11

原版问题

每次请求 → EXPIRE 一次。活跃用户每秒 N 个请求 = 每秒 N 次 Redis 写。

改造

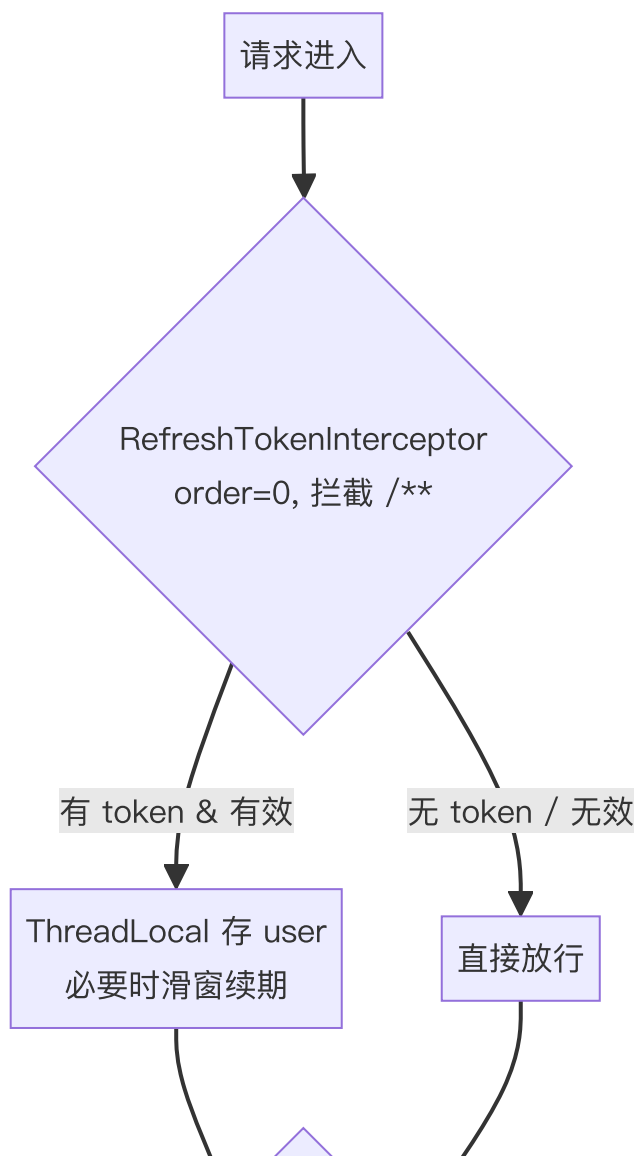
读 token 后先 TTL，仅当剩余 < 阈值（默认 600s）才 EXPIRE。

```
Long ttl = redis.getExpire(key, SECONDS);
if (ttl > 0 && ttl < props.getRefreshThresholdSeconds()) {
    redis.expire(key, props.getTokenTtlSeconds(), SECONDS);
}
```

Token 续期对比（30 分钟 TTL）



活跃会话写次数 6→1 (约 -83%)



总结 & 可继续扩展方向

11 / 11

